



Security Auditing

Lesson#8

Introduction to Digital Forensics and Forensics Readiness

School Year 2025/2026

Master in Informatics Security (MSI) / Master in Informatics Engineering (MEI)

Informatics Engineering Department

University of Coimbra



Learning Objectives

By the end of this class, students should be able to better understand:

- The Forensics Mindset and Legal Pillars.
- The role and process of Forensics in the Corporate/Organization Ecosystem.
- The relevance of Forensics Readiness.
- Technical foundations of forensics such as data volatility and bit-stream imaging.



Part 1

The Forensic Mindset & Legal Pillars



Auditor vs. Investigator

- The Auditor perspective (compliance): verification of controls against a standard (ISO27001/NIS2). Focuses on existence and design.
- The Investigator perspective (forensics): reconstruction of events using artifacts. Focuses on activity and intent.

You've spent weeks learning how to check if a policy exists. Now, we assume the policy was either bypassed or ignored. An auditor asks, "Do you have a firewall?" An investigator asks, "Which packets bypassed the firewall rule at 03:00 UTC?". We are moving from preventive checks to reactive truth-finding.



Locard's Exchange Principle* in the Digital Realm

“Every contact leaves a trace”

In the scope of digital systems, considering for instance a Windows computer, the OS is a constant logger, generating multiple artifacts:

- User -> Files (LNK files, Shellbags)
- Process -> Memory (RAM strings, Pagefile)
- System -> External (Registry, USB logs)

How about for networks?

In physical forensics, this is hair or DNA. In digital forensics, this is metadata. Even if a user doesn't “save” a file, the OS creates a thumbnail, a prefetch entry to speed up the app, and a registry key for the window position. The “trace” is inevitable; the challenge is finding it before it's overwritten.



Legal Pillar I: Admissibility & the Daubert Standard*

Can the evidence be used in court/arbitration?

- Main criteria:
 - Is the tool peer-reviewed and tested?
 - Is there a known error rate?
 - Was the process repeatable? (will another expert get the same result?)

Technical brilliance isn't enough in a professional/legal setting. As CS majors, you might write a Python script to recover a file. That's great for a CTF, but in a forensic environment you must prove that script didn't alter the data. This is why we must use industry-standard, legally vetted tools like Autopsy or SleuthKit.

* https://en.wikipedia.org/wiki/Daubert_standard



Legal Pillar II: The Chain of Custody

The “Paper Trail”...

- Who collected the evidence?
- Where was it stored?
- Who accessed it and why?

A gap in the chain implies a “window of tampering”!

If you leave a suspect's hard drive on your desk while you go to lunch, the Chain of Custody is broken. Defense counsel will argue that anyone could have modified the data. In forensics, control of the physical medium is as important as the binary data.



Legal Pillar III: Evidence Integrity

For instance, using cryptographic hashes as a “Digital Fingerprint”:

- hash the original source.
- create the forensic image for investigation purposes.
- hash the image
- If Hash (Original) = Hash (Image), the evidence is valid
- Who accessed it and why?

How to eliminate the risk of hash collisions?

In forensics, we often use “Dual Hashing” (MD5 and SHA-256 simultaneously) to mathematically eliminate the possibility of an accidental or intentional collision. If one bit changes on a 2TB drive, the hash fails. There is no “close enough” in integrity.



The Acquisition Rule: Never Work on Original Evidence

The original source is “sacred”!

- Original Source -> Bitstream Image -> Working copies

There are some exceptions, such as live memory analysis (RAM), where the act of collecting changes the data (minimum footprint principle).

You should never analyze a suspect's drive by plugging it into your Windows machine and browsing folders. Why? Because Windows will automatically write “System Volume Information”, update “Last Accessed” timestamps, and create “Thumbs.db” files. You have now tampered with the crime scene.



Hardware Write Blockers (the “Forensic Bridge”)

Physical or logical devices that allow “read” commands, but intercept and drop “write” commands.

- Hardware bridges
- Software bridges (less reliable in principle)

<https://dataexpert.eu/products/forensic-hardware-tableauopentext/tableau-forensic-write-blockers>

Think of a Write Blocker as a one-way valve for data. It sits between the investigated drive and your forensic workstation. Even if your OS tries to “repair” the disk or update a log, the hardware blocker blocks that signal. This is how we ensure that we were physically incapable of altering the evidence.



Part 2

Forensics in the Corporate Ecosystem



The Interconnection Map

The holy trinity: Monitoring – Incident Response – Forensics

- Monitoring sends Alerts to Forensics.
- Forensics sends Root Cause to Incident Response.
- Incident Response sends Post-Mortem to Auditing/Management.

Think of Forensics as the intelligence agency of the IT department...

Monitoring (SIEM) is the radar that sees a 'blip.'

Incident Response is the interceptor F16 jet.

Forensics is the team that analyzes the wreckage to determine if the intercepted plane/missile/drone was a hostile actor or if it was a mechanical failure.

None of these functions work effectively in a silo.



Forensics & Cybersecurity Monitoring

Detection-to-analysis pipeline...

- **The “Detection Gap”**: monitoring tools aggregate logs; they rarely keep full packet captures or memory dumps due to storage costs.
- **Triggered Forensics**: using a SIEM alert to trigger a “Forensic Triage” (e.g., using tools like Velociraptor or KAPE).
- **Synergy**: forensics provides the “Ground Truth” to tune monitoring rules and reduce false positives.

Logging everything is often impossible. Monitoring usually watches “Indicators of Compromise” (IoCs). Forensics goes deeper. If your Endpoint Detection and Response (EDR) alerts on a suspicious PowerShell script on Windows, Forensics looks at the ScriptBlock Logging or AMSI (Windows Antimalware Scan Interface) buffers to see exactly what that script was trying to do in memory.



Forensics & Incident Response (the conflict of interest)

How to balance speed (recovery) and depth (investigation)?

- **IR Goal:** Business Continuity (wipe, Restore, get back to work).
- **Forensics Goal:** preservation (don't touch anything, identify the intruder).
- **The compromise:** forensic-aware IR. “Snapshots” over “Wipes”.

This is a major management challenge. Management wants the website back up in 10 minutes. If you wipe the server to fix it, you destroy the evidence of how they got in. You might be back online, but the “backdoor” is still there. Capturing a “Triage Image” first takes 10 minutes and saves the evidence before the restore.



Forensics & Compliance (NIS2)

NIS2 requires “Essential Entities” to have incident handling capabilities

(Article 21 - Cybersecurity risk-management measures)

- Evidence of Due Care:** if you cannot prove how a breach happened, regulators may deem your security “negligent”.
- Accountability:** forensics provides the documented proof required for mandatory breach notifications (within 24/72 hours).

Under NIS2, the stakes have changed. You are legally required to report significant incidents. If your report just says: “We don't know what happened because we didn't have logs”, you are opening the company to massive fines. Forensics is your legal insurance policy.



Auditing the Audit

Forensics may act as a “Quality Control” for the Auditor

- **The Checklist Fallacy:** a checkmark on an audit doesn't mean a control is working.
- **Forensic Verification:**
 - Audit: do we have a policy against unauthorized USBs? (Check: Yes).
 - Forensics: Let's check the Registry for USBSTOR keys.
(result: 50 unknown devices found!)
- **Outcome:** Forensic findings drive the next Audit cycle.

*Auditors are often lied to (usually through ignorance, sometimes intentionally).
Forensics doesn't listen to what people say; it looks at what the machine did.
This is why the best Cybersecurity Auditors have a forensic background.*



The Cost of Unpreparedness (Proactive vs. Reactive)

- **Reactive forensics (ad-hoc):**

High cost, slow response, low evidence integrity, business downtime.

- **Proactive (ready):**

Lower cost, automated collection, high integrity, surgical response.

The “Forensic Tax”: Investing in readiness now avoids the “Catastrophe Tax” later.

A reactive investigation costs roughly €300–€500 per hour for external consultants. If they have to spend 20 hours just finding where your logs are stored, you’ve wasted €10,000 before the investigation even starts. Forensic Readiness is about making the investigation “cheap and fast” so you can do it more often and more accurately.



Part 3

Forensic Readiness



The concept of Forensic Readiness

The ability of an organization to maximize its potential to use digital evidence while minimizing the costs of an investigation

Main goals:

- Maximizing the capability to collect useful evidence.
- Minimizing the cost to the business (downtime and legal fees).

The “Forensic Tax”: Investing in readiness now avoids the “Catastrophe Tax” later.

Most people think forensics starts after the hack. Actually, forensics should start during the design phase of the system/network. If we aren’t ready, we are just “getting lucky” with whatever data happens to be left over. Readiness is the difference between a 2-hour investigation and a 2-month investigation.



Pillar 1: Time Synchronization

The Problem: Log desynchronization.

If the Firewall is 2 minutes ahead of the Web Server, the timeline is broken.

The Solution: Time synchronization (e.g. using Network Time Protocol (NTP)).

Audit Check: Are all “Essential Entities” (under NIS2) syncing to a Stratum 1 or Stratum 2 time source?

The *Drift*: Physical and virtual machines can *drift* in time; how is this monitored?

In a court of law, if you can't prove exactly when an event happened because your clocks were off, your evidence can be thrown out. In forensics, we often need sub-second synchronization across the entire enterprise to correlate a “Login” on machine A with a “File Access” on machine B.



Pillar 2: Advance Logging Policy

Move beyond “IT Troubleshooting” logs to “Forensic-Quality” logs

–**Troubleshooting Logs:** “Did the service start?” (useless for forensics)

–**Audit Logs:** “Who ran which command, from which IP, and what was the result?”

For instance, for Windows:

- Event ID 4688: Process Creation (with Command Line args).
- Event ID 4624: Success Logons (including Source IP).
- PowerShell ScriptBlock Logging.

*By default, Windows is quiet. It doesn't tell you what was typed into a command prompt. Forensic readiness means turning on “Command Line Logging”. Without this, you see that cmd.exe ran, but you don't know if the attacker typed dir or del *.* /s /q.”*



Pillar 3: Legal Mandate & Right to Monitor

Technical ability not always matches legal authority

–Privacy vs. Security:

does the company have the legal right to image an employee's laptop?

–**The requirement:** explicit "Banner Messages" and Employment Contract clauses.

–**GDPR/NIS2 Context:** balancing the “legitimate Interest” of security with the “Privacy Rights” of individuals.

You can have the best forensic tools in the world, but if your HR policy doesn't explicitly state that corporate assets are subject to monitoring, you might be breaking privacy laws by doing your job. An auditor must check the Employee Handbook just as closely as the Firewall Config



Pillar 4: Technical Triage Tools

“Remote/Fast” forensics

- Traditional:** physically seize the drive (high friction).
- Modern (Readiness):** pre-deployed “Triage Agents”
- Tools:** Velociraptor, KAPE, EDR-integrated tools, etc.
- Benefit:** collect critical artifacts (RAM, Registry) in minutes, over the network.

We need to be efficient. If you have 500 workstations in 5 different cities, you can't fly a tech to each one. Forensic readiness means having an “agent” already sitting there, waiting for your command to securely upload a memory dump.



Pillar 5: Staff Training & the First Responder

The first person to see a hacked machine is usually a Helpdesk junior

Common mistakes:

- Rebooting the machine (clears RAM).
- Running antivirus (alters “Last Accessed” timestamps).
- Logging in as “Admin” (overwrites registry keys).

“Ready” staff isolates the network (unplug the cable) but leaves the power ON.

Training your IT staff is a forensic control. If the helpdesk “fixes” the problem before you arrive, they have effectively burned the crime scene to the ground. Part of forensic readiness is having a “First Responder Guide” in every IT office.



The Forensic Readiness Checklist (Summary)

Checklist

- Time Synchronization
- Advanced Logging Policies
- Legal Mandate & Right to Monitor
- Technical Triage Tools
- Staff Training & The First Responder

If you were auditing a company today, and they had 100% perfect logs but NO legal banner on their computers, are they forensically ready?

Auditor Goal: can you provide a "Yes/No" for each pillar for your organization?

Management Goal: what is the Return on Investment for fixing these gaps?

This checklist is what you take back to your management. You don't just tell "we need forensics". You tell "We are failing Pillar 2 and Pillar 5, which means our IR plan will fail 80% of the time". This is how you use forensics to drive security spending.



Part 4

Technical Foundations



The Order of Volatility (RFC 3227*)

The Golden Rule: collect data from the most volatile to the least volatile.

The hierarchy:

- Registers & Cache (nanoseconds)
- RAM (the “State of Play”)
- Network State (current connections/ARP cache)
- Disk/Physical Media (persistent storage)

In Computer Science, we think of memory hierarchy in terms of speed.

In Forensics, we think of it in terms of survivability. If you pull the power plug, you lose the top three layers instantly. For an auditor, this means that if your incident response plan starts with “Reboot the server”, you are actively destroying evidence.

* <https://www.rfc-editor.org/rfc/rfc3227.html>



Live vs. Dead Acquisition

Dead Box (static): imaging a powered-off drive (safest, easiest to hash).

Live Acquisition (dynamic): Imaging while the OS is running.

The trade-off: live acquisition alters the system (minimal footprint), but it is the only way to get encryption keys and RAM.

You will hear purists say “always pull the plug”, but if the drive is encrypted with BitLocker or FileVault, and you don’t have the recovery key, that drive is now a paperweight. Live Acquisitions may capture the keys while they are “unlocked” in memory.



RAM: the new Smoking Gun

What lives in RAM:

- Plaintext passwords and decrypted keys.
- Unsaved documents (Word/Notepad).
- Malware processes hiding from the OS.
- Recent CLI commands.

Malware has evolved. “Fileless” malware doesn't sit on the disk where an antivirus can scan it. It lives in the memory space of a legitimate process (like explorer.exe). RAM is a dump of active data structures. Tools such as Volatility 3 can “carve” these structures out of a raw memory dump.



Bit-Stream Imaging (physical vs. logical)

Copying vs Forensic Imaging

–Logical Copy:

Copying files recognized by the File System (what you “see” in Explorer).

–Physical Bit-Stream:

Sector-by-sector clone of the entire physical disk (e.g. *dd* format).

– Why Physical?

It captures deleted files, partition tables, and “unallocated space”.

If you just “Copy-Paste” a folder, you miss half the story. A Bit-Stream image is a clone of the 0s and 1s. If there was a hidden partition or a deleted database, the Bit-Stream image captures it. This is why forensic images are usually the exact same size as the physical hard drive.



Hex & File Signatures (Magic Bytes)

Break the reliance on file extensions

- The OS Lie:** file extensions (.jpg, .exe) are just suggestions for the OS.
- The Truth:** The first few bytes of a file (the Header) define its type.
- Examples:** (for Windows)
 - 4D 5A (MZ) = Executable.
 - 25 50 44 46 (%PDF) = PDF.
 - FF D8 FF = JPEG.

Attackers rename malware.exe to picture.jpg. A standard user (or some auditors) might be fooled. A forensic tool ignores the extension and reads the header.



Suggested Reading List

- [NIST Special Publication 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile](#)
(global standard for how organizations should structure their response)
- [RFC 3227: Guidelines for Evidence Collection and Archiving](#)
(short, foundational technical document on volatility)
- [Tan, J. \(2001\). Forensic Readiness](#)
(seminal paper that originally coined the term “Forensic Readiness”)
- [ENISA: Strategies for Incident Response and Cyber Crisis Management](#)
(discusses how the EU expects member states and “Essential Entities” to handle forensic evidence during cross-border incidents)